

TITLE: TESTING THE SECURITY OF A COMPUTER SYSTEM

Contents

1. Abstract	Pg 4
1.1 Task 1	
1.2 Task 2	
1.3 Task 3	
1.4 Task 4	
1.5 Task 5	
2. Introduction	Pg 4
2.1 Overview/Scope	4
3. Information gathering	Pg 5
3.1 Overview	5
4. The Attack Narrative	Pg 6
2.2 PTES	
2.2.1 Scope	
2.2.2 Information Gathering	
2.2.3 Vulnerability analysis	
2.2.4 Risk assessment	
2.2.5 Exploitation	
2.2.6 Post Exploitation	
2.2.7 Reporting	
2.3 Tools used Kali and VMware workstation	
4.1 Vulnerability, Exploit and Mitigation	
4.1.1 Default Database Credentials	
4.1.1.1 Vulnerability	
4.1.1.2 Risk Assessment	
4.1.1.3 Exploitation	
4.1.1.4 Mitigation Methods	
4.1.2 HASH Encryption	
4.1.2.1 Vulnerability	
4.1.2.2 Risk Assessment	
4.1.2.3 Exploitation	
4.1.2.4 Mitigation Methods	
4.1.3 Netcat Remote Shell	
4.1.3.1 Vulnerability	
4.1.3.2 Risk Assessment	
4.1.3.3 Exploitation	
4.1.3.4 Mitigation Methods	

4.1.4	Nessus for DoS	
4.1.4.1	Vulnerability	
4.1.4.2	Risk Assessment	
4.1.4.3	Exploitation	
4.1.4.4	Mitigation Methods	
4.1.5	Unencrypted Credential Exposure	
4.1.5.1	Vulnerability	
4.1.5.2	Risk Assessment	
4.1.5.3	Exploitation	
4.1.5.4	Mitigation Methods	
5.	Post Exploitation	Pg 15
5.1	Exploring databases in PhpMyAdmin after exploit	
5.2	Post exploit of WordPress credentials	
5.3	Service after DoS attack	
5.4	Viewing and adding files after backdoor through NetCat	
6.	Conclusion	Pg 16
6.1	Vulnerability Assessment Results	
6.2	Mitigation Strategies	
6.3	Proactive Resilience Enhancement	
7.	Appendixes	Pg 17
7.1	Nmap used for information gathering	
7.2	Dirb Scan	
7.3	Nessus scan	
7.4	Nessus scan for vulnerabilities	
7.5	Encrypted password file for WordPress	
8.	References	Pg 24

Pen Testing Report for Target 192.168.3.88

1. Abstract

The purpose of this report is to display penetration test conducted on a machine. Also, it explains the exploitation of the vulnerabilities and give mitigation methods for it. Furthermore, the project consists of five task which includes 5 vulnerabilities found with 4 successful exploitations done on the testing computer or the target machine which has a Linux operating system.

1.1 Task 1

Using the dirb command to scan and find the websites running on the target machine. Exploiting the vulnerabilities found on webpages. The found webpage here was a database known as PhpMyAdmin.

1.2 Task 2

The vulnerability found is an encrypted password on the database of the target machine and exploitation is decrypting it.

1.3 Task 3

Using Kali tools to find open ports with bind-shell service running on it and exploiting it using suitable tool to gain backdoor remote access.

1.4 Task 4

Dos attack took place which means Denial of Service attacks that stops all the services running on the target machines webpages. The vulnerability found is through a Nessus scan.

1.5 Task 5

Scanning passwords using a tool in Kali through.txt file. The correct password will give remote access for the SSH client user for TCP port 22. The task was unsuccessful due to lack to time.

2. Introduction:

2.1 Overview/Scope

This penetration test report documents the findings of a comprehensive security assessment performed on a singular Linux machine, identified by the assigned IP address 192.168.3.88. The objective of this examination was to evaluate the resilience of the system against potential cyber threats and identify vulnerabilities that could compromise its security. The

primary aim is exploiting the vulnerabilities found using kali on a virtual environment. The test is conducted under the framework or methodology of Penetration Testing Execution Standards (PTES) the report further will discuss about the technology and techniques used for it.

2.2 PTES

Penetration Testing Execution Standard is a methodology and guideline for conducting penetration testing and ethical hacking. It provides a standardized approach to planning, executing, and documenting penetration tests to ensure consistency, thoroughness, and professionalism in the testing process.

The key components and the systematic approach while following the standards of PTES are listed below:

2.2.1 Scope 2.2.2 Information Gathering 2.2.3 Vulnerability Analysis 2.2.4 Risk Assessment
2.2.5 Exploitation 2.2.6 Post Exploitation 2.2.7 Reporting

2.3 Tools used- Kali and VMware Workstation

Kali Linux is a specialized Linux distribution designed for penetration testing, ethical hacking, and cybersecurity tasks. It comes pre-installed with a wide range of security tools and software, making it a go to choose for security professionals. Kali Linux is based on Debian and provides a robust environment for conducting security assessments, vulnerability analysis, and penetration testing.

VMware Workstation is a virtualization software that enables users to run multiple operating systems on a single physical machine. It allows the creation and management of virtual machines and provides a virtualized environment for testing and development. VMware Workstation supports a variety of guest operating systems, making it a popular choice for running virtualized environments on desktop computers.

Although, to run kali on a PC which is hosted on Windows or any other operating system it is crucial to engage with a virtual environment on it which is VMware workstation here.

3. Information Gathering

3.1 Overview

Information gathering involves collecting data about the target system or network. Here we gathered information by using **Nmap** to discover the ports and information regarding it. **Dirb** for scanning websites for and **Nessus** for vulnerability finding for analysing the targets potentials. By the information gathered I opted for certain vulnerabilities to be exploited as the details about them are mentioned below.

4. The Attack Narrative

The attack narrative here describes about the 5 vulnerabilities and the risks analysed among which 4 are successfully exploited. Simultaneously, the techniques used to identify vulnerabilities and steps taken during penetration test and exploitation are mentioned below followed by the measures to mitigate them.

4.1 Vulnerabilities, Exploitation and Mitigation

4.1.1 Default Database Credentials

4.1.1.1 Vulnerability

The discovery of a vulnerability surfaced during an extensive dirb scan using the command (***dirb http://192.168.3.88***). Dirb is a powerful tool used for web application security testing, uncovering information about the interconnected websites. Within the list of identified webpages, a specific link was encountered ***http://192.168.3.88/phpmyadmin/***. The noteworthy aspect was the reliance on HTTP, inherently devoid of encryption for its offered services. This issue poses a substantial security risk, as the lack of encryption in HTTP exposes transmitted data to potential eavesdropping and various security threats.

4.1.1.2 Risk Assessment

The discovery of the vulnerability, <http://192.168.3.88/phpmyadmin/>, poses a significant risk due to its reliance on unencrypted HTTP. This exposes transmitted data to eavesdropping and potential security threats. There are very few default combinations of this database that are set, which usually users change before establishing the database. The combinations can vary if they run it through XAMP or USB-webserver. Additionally, the use of default credentials in PhpMyAdmin or MariaDB amplifies the risk, as unauthorized access could compromise sensitive information

These are the first option what attackers try while attempting to exploit the database. The figure 1.1 below displays the proof of the phpMyAdmin page found.



Figure 1.1

4.1.1.3 Exploitation

The vulnerability, elaborated in above section, revolves around the successful exploitation of the PhpMyAdmin database. Upon thorough dirb exploration, it was revealed that the database was configured with default credentials. The username 'root' and an empty password were sufficient for unauthorized access. This vulnerability exposes a significant security lapse, as default or weak credentials provide an effortless entry point for potential attackers. The exploitation process required minimal effort, emphasizing the critical importance of promptly addressing this security flaw to prevent unauthorized access and potential data compromise.

The exploitation done by entering database dashboard are displayed below in the figure 2.1.



Figure 2.1

4.1.1.4 Mitigation Methods

The mandatory methods for mitigation that are supposed to be applied here are to change the default credentials, particularly for the 'root' user, by setting strong and unique passwords. Conducting regular audits of user permissions, restricting access to only necessary individuals, and monitoring login activity can help detect and prevent unauthorized access. Network segmentation should be considered to limit access to PhpMyAdmin from external sources. User education on the importance of strong passwords is essential, along with the encouragement of password management tools. Disable or rename default accounts, and have an incident response plan in place for effective security management.

4.1.2 HASH Encryption

4.1.2.1 Vulnerability

While navigating through PhpMyAdmin, I stumbled upon a database that contained valuable information about the target system's WordPress setup. Within this database, a specific table named "wp_users" caught my attention, signalling the storage of potentially sensitive user data. As anticipated, one user, identified as 'admin,' was present in the table, and the associated password was encrypted.

4.1.2.2 Risk Assessment

The potential threat it presents to the target system is recognizing that the password was subjected to HASH encryption, I observed its distinctive characteristics, such as a length of 32 characters and the use of hexadecimal characters. Several online tools like 'hashidentifier' and 'Hashid' can assist in identifying such hash types. However, leveraging Kali Linux, which comes equipped with specialized tools, offers a more efficient approach. In this case, the tool of choice is 'John the Ripper,' designed to decrypt passwords through a straightforward command.

Recognizing the distinctive traits of the hash, I opted for the Kali Linux environment with its built-in tools, utilizing 'John the Ripper' to decrypt the password efficiently. The encryption which is identified as a vulnerability is marked in Figure 1.2.

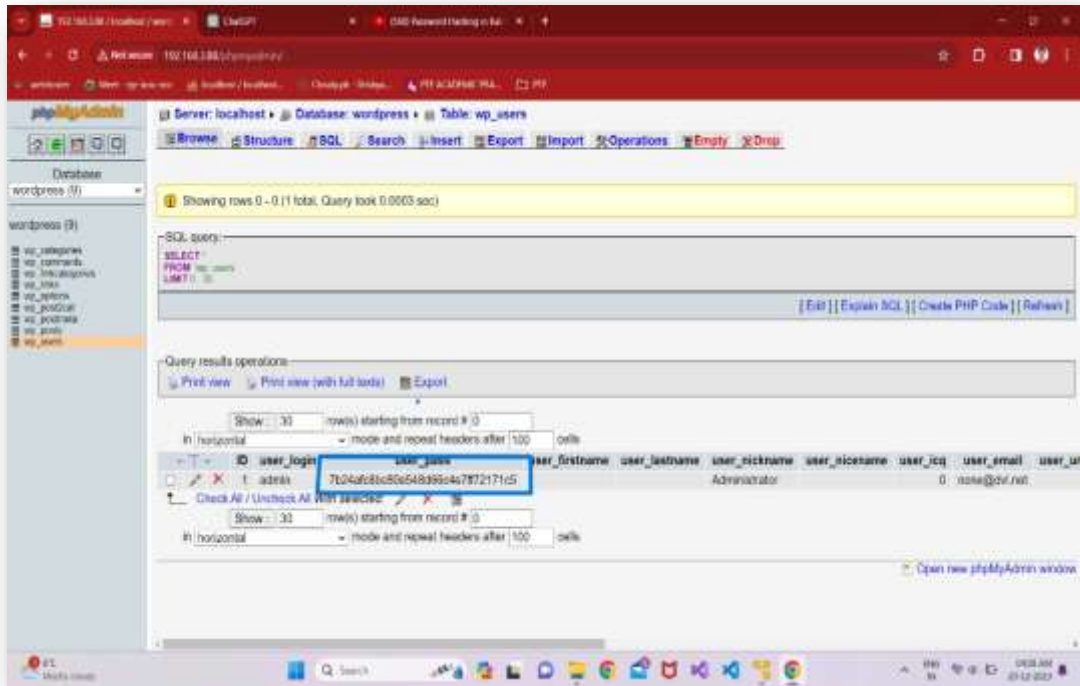


Figure 1.2

4.1.2.3 Exploitation

The vulnerability is extensively detailed in above section, focusing on an encrypted password discovery within phpMyAdmin. Specifically, the WordPress database password encryption was identified as HASH, presenting a potential security risk. The exploitation of this vulnerability occurred seamlessly using Kali Linux, utilizing the John the Ripper tool, which successfully cracked the MD5 encryption and the password appeared as 'toor'. The encryption was saved in a file called **assgpass.txt** and the command used to exploit is **(john assgpass.txt --format=Raw-MD5)**. Despite HASH encryption's prevalence, it is notable for its simplicity, making it easily recognizable based on its distinctive characteristics. This underscores the importance of robust encryption practices and the need for heightened security measures to counteract such vulnerabilities.

The exploitation done by decrypting password are displayed below in the figure 2.2.

```
john -w /usr/share/john/password.lst --format=Raw-MD5
(kali@kali)~$ john assgpass.txt --format=Raw-MD5
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 128/128 AVX 4x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:ASCII
toor (?)
lg 0:00:00:03 DONE 3/3 (2023-12-18 22:30) 0.2544g/s 1391Kp/s 1391Kc/s 1391KC/s clzn..tubg
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

Figure 2.2

4.1.2.4 Mitigation Methods

The foremost mitigation method to be used here is to strengthen password security by adopting complex, unique passwords and avoiding easily guessable terms. Furthermore, consider upgrading to a more secure encryption method, such as bcrypt or any other, for storing passwords, as it offers enhanced resistance against brute-force attacks. Regularly updating software, including phpMyAdmin and WordPress, is essential to patch any known vulnerabilities.

4.1.3 Netcat Remote Shell

4.1.3.1 Vulnerability

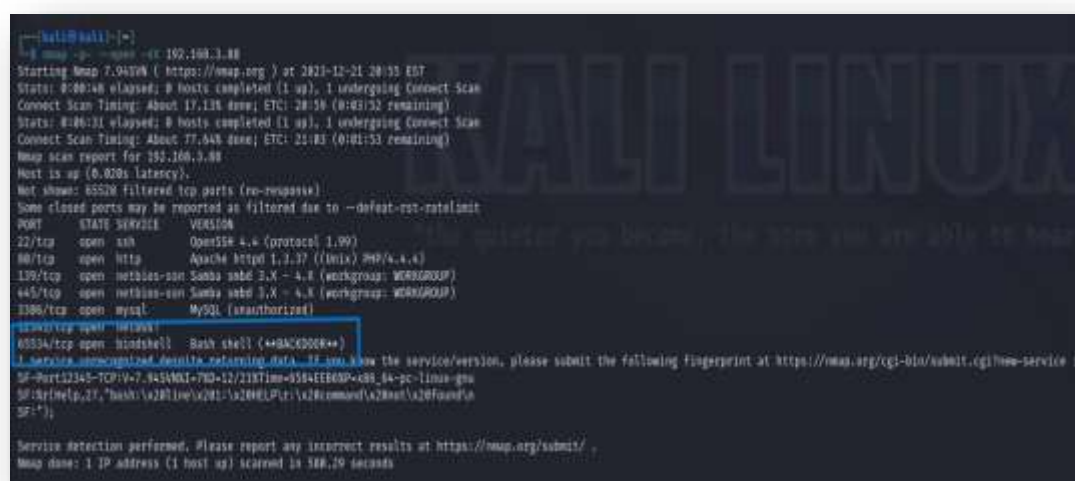
The vulnerability came to light through the use of Nmap, a powerful network scanning tool crucial for unveiling devices and services within a computer network. The identification of the open port **65534** is particularly concerning, signalling potential risks to the target system. This scenario creates an opportunity for malicious actors to exploit vulnerabilities, employing tools like NetCat. Taking action to exploit by utilizing this open

port to access the overall system and compromising potential security measures will be counted as a vulnerability here.

4.1.3.2 Risk Assessment

Utilizing the Nmap command (***sudo nmap -p- --open -sV 192.168.3.88***) to identify open ports, the pinpointed port **65534**, was signalling a bash shell – precisely what I wanted as this poses a potential risk to the target system. This particular open port held the key to potential remote access to the target system. Leveraging the identified port number, I aimed to exploit this opening.

To exploit the open port and facilitate remote access, the tool of choice was netcat abbreviated as nc, a built-in utility in Kali Linux. The vulnerability is shown in a marked section below in the figure 1.3.



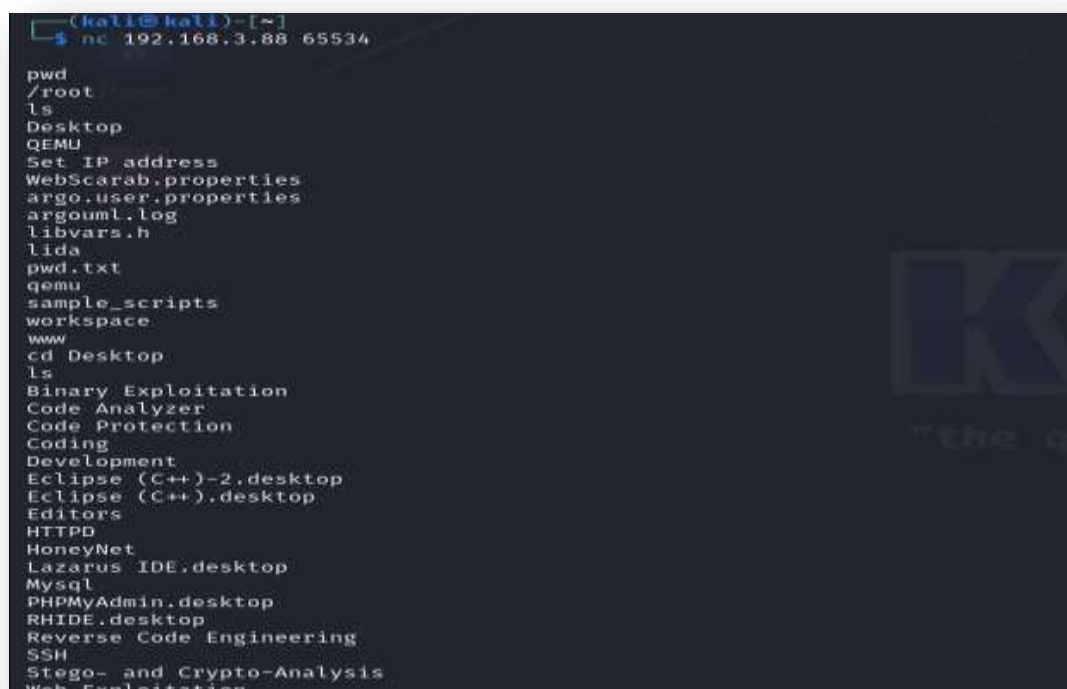
```
kali@kali:~$ sudo nmap -p- --open -sV 192.168.3.88
Starting Nmap 7.94SVN ( https://nmap.org ) at 2023-12-21 20:55 EDT
Stats: 0:00:148 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 17.13% done; ETC: 20:56 (0:03:52 remaining)
Stats: 0:06:31 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 77.64% done; ETC: 21:03 (0:01:53 remaining)
Nmap scan report for 192.168.3.88
Host is up (0.020s latency).
Not shown: 65528 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 4.4 (protocol 1.99)
80/tcp    open  http      Apache/2.0.46 ((Ubuntu)) PHP/4.4.4
139/tcp   open  netbios-ssn Samba smbd 3.0.2a-4.0 (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.2a-4.0 (workgroup: WORKGROUP)
3306/tcp  open  mysql     MySQL (unauthorized)
65534/tcp open  bindshell  Bash shell (+BAC00000+)
I have generated detailed nmaping data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port12345-TCP|V=7.94SVN|I=703-12/218TIm=9564EEB0P<08_64-pc-linux-gnu
SF-StrInIp,27,"bash:\a281ne\c01:\a280LPtr:\a280omand\c280ut\c280Foundfa
SF:");
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 148.29 seconds
```

Figure 1.3

4.1.3.3 Exploitation

The identified vulnerability emerged during the Nmap scan in the information gathering phase. Employing the command (***sudo nmap -p- --open -sV 192.168.3.88***), open ports were revealed, and further details are outlined in section above. Subsequently, successful exploitation took place using Netcat, providing remote access to the root user and thereby granting extensive administrator privileges. The exploitation here carried tasks viewing the directories and files also by creating a text file which would be an activity done by the malicious actor on gaining access. The command (***nc 192.168.3.88 65534***) facilitated the establishment of a backdoor for unauthorized access. This exploit underscores the critical importance of securing open ports and implementing robust access controls to prevent unauthorized entry points and potential administrator-level breaches.

The evidence of exploit done by gaining root access through netcat by viewing directories and files in it are displayed below in the figure 2.3

A terminal window showing a netcat listener on Kali Linux. The prompt is '(kali@kali)-[~]'. The command 'nc 192.168.3.88 65534' is entered. The connection is established, and the user runs 'pwd', showing '/root'. Then 'ls' is run, displaying a long list of files and directories including Desktop, QEMU, Set IP address, WebScarab.properties, argo.user.properties, argouml.log, libvars.h, lida, pwd.txt, qemu, sample_scripts, workspace, www, and cd Desktop. Finally, 'ls' is run in the Desktop directory, showing a list of folders like Binary Exploitation, Code Analyzer, Code Protection, Coding, Development, Eclipse (C++)-2.desktop, Eclipse (C++).desktop, Editors, HTTPD, HoneyNet, Lazarus IDE.desktop, Mysql, PHPMyAdmin.desktop, RHIDE.desktop, Reverse Code Engineering, SSH, Stego- and Crypto-Analysis, and Web Exploitation.

```
(kali@kali)-[~]
$ nc 192.168.3.88 65534
pwd
/root
ls
Desktop
QEMU
Set IP address
WebScarab.properties
argo.user.properties
argouml.log
libvars.h
lida
pwd.txt
qemu
sample_scripts
workspace
www
cd Desktop
ls
Binary Exploitation
Code Analyzer
Code Protection
Coding
Development
Eclipse (C++)-2.desktop
Eclipse (C++).desktop
Editors
HTTPD
HoneyNet
Lazarus IDE.desktop
Mysql
PHPMyAdmin.desktop
RHIDE.desktop
Reverse Code Engineering
SSH
Stego- and Crypto-Analysis
Web Exploitation
```

Figure 2.3

4.1.3.4 Mitigation Methods

To mitigate the vulnerability found and the exploit done the measures that should take place are conduction of regular port scanning and vulnerability assessments to proactively identify and address potential weaknesses. Furthermore, applying the principle of least privilege by carefully defining user permissions, minimizing access to only essential resources. Implementation of strong firewall rules to control inbound and outbound traffic, reducing the attack surface.

4.1.4 Nessus For DDOS

4.1.4.1 Vulnerability

The attack I was planning here to do is a DDOS attack. A comprehensive Nessus vulnerability scan was conducted on the web servers, revealing numerous critical issues. In response to these findings, I explored the feasibility of a Denial-of-Service (DDoS) attack as a means to evaluate the servers' resilience under stress. Recognizing the complexity of developing a Python script for this purpose, I opted to leverage an existing slowloris.py file available online and edited the script with minor changes.

4.1.4.2 Risk Assessment

The objective of a DDoS attack is to disrupt services by inundating the target with a high volume of simultaneous socket connections. In both offensive and defensive contexts, Wireshark emerged as a crucial tool. It enables both attackers and defenders to analyse incoming sockets from each IP address, facilitating in-depth risk analyses.

To execute the DDoS simulation, a straightforward command was employed (***python3 slowloris.py 192.168.3.88 -s 8000***). The vulnerabilities are identified through Nessus scan a brief is displayed in figure 1.4 below.

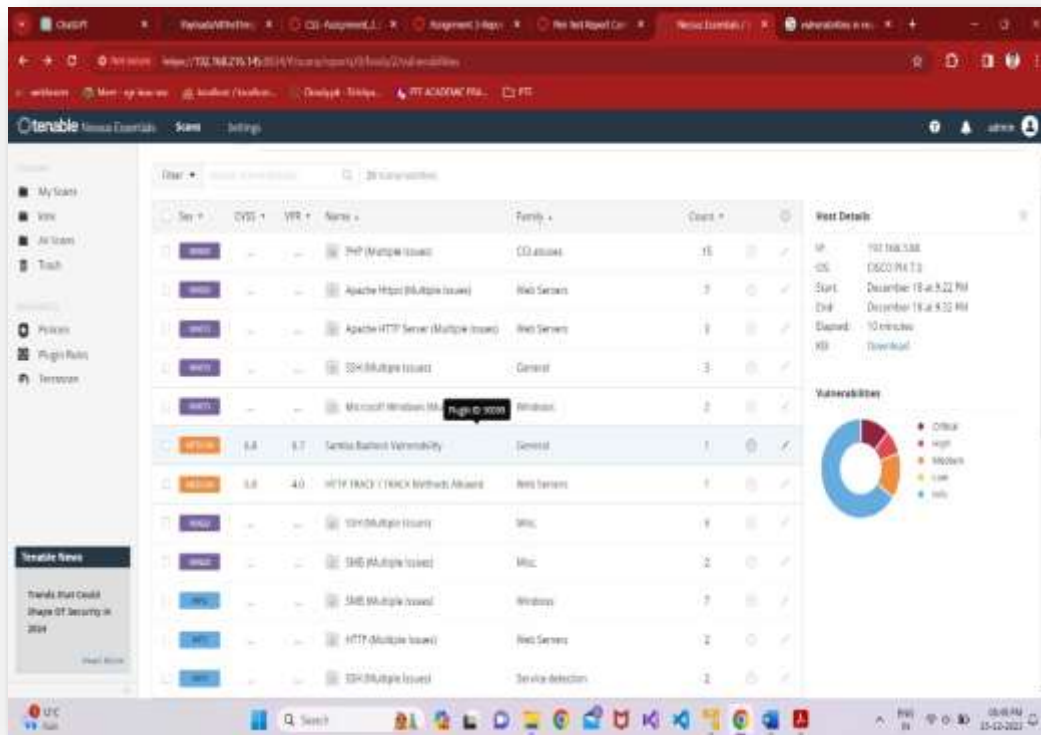


Figure 1.4

4.1.4.3 Exploitation

The vulnerability, initially identified during a Nessus scan, pointed out weaknesses in the web servers, detailed in section 4.1.4.1. These vulnerabilities suggested a potential susceptibility to a Denial-of-Service (DoS) attack. Subsequently, a successful DoS attack was executed using the slowloris Python script, sourced online. This script deployed sockets to overload the server, causing the webpages to cease functioning once the attack commenced. The command employed for this attack was (***python3 slowloris.py 192.168.3.88 -s 500***). This incident highlights the critical importance of fortifying web servers against potential DoS attacks and underscores the need for robust security measures to ensure uninterrupted service availability.

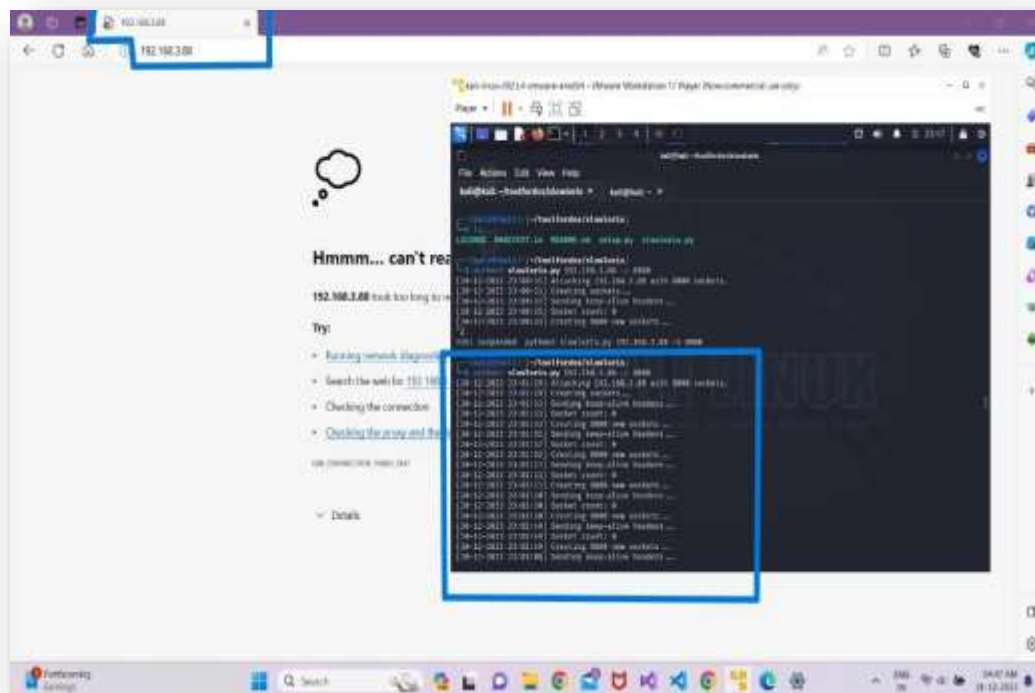
4.1.4.4 Mitigation Methods

The key steps to reduce the risk of such attacks is to implement rate limiting and connection control mechanisms to restrict the number of requests from a single IP address within a specific timeframe, reducing the impact of potential DoS attempts. Configuring web servers to gracefully handle high loads by optimizing server resources and employing load balancing techniques. This can distribute incoming traffic across multiple servers. A comprehensive incident response planning is needed to promptly detect, assess, and respond to DoS attacks automatically.

The exploit done is stopping the services of the website the screenshots below displayed how webpage worked before in figure 2.4 and after in figure 2.5 starting the attack.



Before - Figure 2.4



After - Figure 2.5

4.1.5 Unencrypted Credentials Exposure

4.1.5.1 Vulnerability

During the dirb scan, a critical vulnerability surfaced as I explored the webpages. A specific webpage, accessible at (<http://192.168.3.88/true/>), revealed unencrypted credentials for the target IP. While usernames were visible presenting a potential avenue for exploitation by malicious actors. The primary vulnerability found would be successful medusa attack which would disclose the credentials which couldn't happen here.

4.1.5.2 Risk Assessment

Moreover, the risk for the system is maximized as these credentials and also the absence of password encryption heightened the risk, once in the hands of an attacker, grant remote access to each identified user. Notably, a prior Nmap scan exposed an open SSH port (port 22) with a TCP service running, providing an exploitable entry point for an attacker.

Exploiting the system involves two steps: if the password is known connect it through ssh which will prompt a password dialogue. Though, if the password is unknown, using medusa tool to break password through files containing combination of passwords on Kali. The figure 1.5 displays the way to find vulnerability for each user.

```

Username, Password
frodo, Baggins1
bilbo, Baggins1
samwise, Gamgee
faramir, T00k

File has been updated. See following link:
https://www.youtube.com/watch?v=RfiQYRn7fBg
frodo password has been updated with password policy dictionaryentry (e.g. bourbaki).
samwise password has been updated with password policy dictionaryentry (e.g. bourbaki).
faramir password has been updated with password policy dictionaryentry (e.g. bourbaki).
bilbo password has been updated with password policy dictionaryentry (e.g. bourbaki).

```

Figure 1.5

4.1.5.2 Exploitation

The vulnerability found was through a dirb scan as stated above in the section 4.1.5.1. The file consisted four usernames and passwords listed below in the table.

S. No	Username	Password
1	frodo	Baggins1
2	bilbo	Baggins1
3	samwise	Gamgee
4	faramir	T00k

However, attempts to exploit this information were thwarted, as the provided passwords were either outdated or incorrect. Regrettably, the exploitation endeavour was hindered by time constraints, impeding the success of the medusa attack in breaking the passwords for each user. The primary challenge stemmed from the extended duration of the medusa attack. The attack utilized the built-in rockyou.txt file in Kali, executed with the following command (***medusa -h 192.168.3.88 -u frodo -P /usr/share/wordlist/rockyou.txt -t 4***). The success would have been thrown the password as a vulnerability for a user and exploitation could take place by accessing the system.

Despite the unsuccessful outcome, this experience underscores the importance of optimizing attack strategies and considering time efficiency in penetration testing scenarios.

4.1.5.2 Mitigation Methods

To mitigate the identified vulnerability stemming from the dirb scan and potential brute-force attacks, several proactive measures can be implemented as account lockout policies to restrict the number of unsuccessful login attempts, preventing attackers from repeatedly trying different passwords within a short timeframe. Moreover, enforcing a strict password policy, mandating the use of strong, complex, and unique passwords. Utilize intrusion detection and prevention systems to identify and block suspicious activities, including repeated login failures indicative of brute-force attempts. By adopting

these measures, organizations can significantly enhance their resilience against brute force attacks.

6. Post Exploitation

After successful exploitation of the identified vulnerabilities, various post-exploitation activities were carried out to gather additional information and assess the extent of access gained.

6.1 Exploring Databases in PhpMyAdmin after exploit

A thorough exploration of databases was conducted. Along with WordPress database several databases were exploited and all the HASH encrypted password found was 'toor' on breaking up the password by john ripper. Besides, the exploration included examining tables, relationships and valuable information was leaked stored in each database.

6.2 Post exploit of WordPress credentials

Following the successful decryption of the WordPress password ('toor'), the post-exploitation phase involves leveraging the compromised credentials to gain unauthorized access to the WordPress website. This access opens avenues for manipulating website content, injecting malicious code, and disrupting services. Exploration of the WordPress environment includes assessing user roles, themes, plugins, and potential vulnerabilities. While specific steps weren't executed in this report, but the possibility of such post-exploitation was accurately high.

6.3 Services after DoS Attack

As part of the post exploitation phase, the impact of successful DoS attack was assessed. This attack and cessation of services allowed for an evaluation of the target system's resilience under stressed conditions.

6.4 Viewing and adding files after backdoor attack through NetCat

Gained remote access was utilized to explore directories and to create files in it this was to assess how the root access work. Furthermore, by this assessment it is vivid that a potential attacker to the target system can readily install virus and infect the system anonymously. Although the user wouldn't have a conception regarding the malicious act performed.

7. Conclusion

7.1 Vulnerability Assessment Results

In conclusion, the penetration test on the system (*IP: 192.168.3.88*) revealed significant vulnerabilities, including default database credentials, HASH encryption weaknesses, an open port susceptible to Netcat remote shell access, and a successful Denial-of-Service (DoS) attack using slowloris. Although attempts to exploit found credentials were unsuccessful, the potential threat of brute-force attacks emphasizes the need for robust security measures.

7.2 Mitigation Strategies

Mitigation strategies, such as changing default credentials, adopting secure encryption practices, fortifying open ports, and enhancing web server resilience, are crucial for improving the system's security posture. Regular security audits, network segmentation, and incident response planning are essential components of a comprehensive security strategy.

7.3 Proactive Resilience Enhancement

While the system exhibits vulnerabilities, proactive implementation of these techniques can significantly enhance resilience against potential cyber threats. Organizations should prioritize promptly addressing these issues to safeguard systems and sensitive data from malicious actors.

8. Appendixes

8.1 Nmap used for information gathering

```
(kali@kali)-[~]
$ nmap --script vuln -oN vulnerabilities.txt 192.168.3.88
Starting Nmap 7.94 ( https://nmap.org ) at 2023-12-11 15:41 EST
Stats: 0:00:19 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 73.20% done; ETC: 15:41 (0:00:02 remaining)
Stats: 0:00:32 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 75.41% done; ETC: 15:41 (0:00:02 remaining)
Stats: 0:00:34 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 75.41% done; ETC: 15:41 (0:00:03 remaining)
Nmap scan report for 192.168.3.88
Host is up (0.018s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_http-trace: TRACE is enabled
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-enum:
| /beef/: BeEF Browser Exploitation Framework
| /beef/images/beef.gif: BeEF Browser Exploitation Framework
| /phpmyadmin/: phpMyAdmin
| /icons/: Potentially interesting directory w/ listing on 'apache/1.3.37'
| /index/: Potentially interesting folder
|_ /manual/: Potentially interesting folder
445/tcp    open  microsoft-ds
3306/tcp   open  mysql
Host script results:
|_smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to debug)
|_smb-vuln-ms10-061: false
|_smb-vuln-ms10-054: false
Nmap done: 1 IP address (1 host up) scanned in 90.76 seconds

(kali@kali)-[~]
$ cat vulnerabilities.txt
# Nmap 7.94 scan initiated Mon Dec 11 15:41:15 2023 as: nmap --script vuln -oN vulnerabilities.txt 192.168.3.88
Nmap scan report for 192.168.3.88
```

8.2 Dirb Scan

DIRB v2.22
By The Dark Raver

START_TIME: Mon Dec 18 22:43:01 2023
URL_BASE: http://192.168.3.88/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

```
--- Scanning URL: http://192.168.3.88/ ---
=> DIRECTORY: http://192.168.3.88/base/
+ http://192.168.3.88/index (CODE:200|SIZE:449)
+ http://192.168.3.88/index.php (CODE:200|SIZE:449)
=> DIRECTORY: http://192.168.3.88/manual/
=> DIRECTORY: http://192.168.3.88/phpmyadmin/
=> DIRECTORY: http://192.168.3.88/true/

--- Entering directory: http://192.168.3.88/base/ ---
=> DIRECTORY: http://192.168.3.88/base/admin/
=> DIRECTORY: http://192.168.3.88/base/contrib/
=> DIRECTORY: http://192.168.3.88/base/docs/
=> DIRECTORY: http://192.168.3.88/base/help/
=> DIRECTORY: http://192.168.3.88/base/images/
=> DIRECTORY: http://192.168.3.88/base/includes/
+ http://192.168.3.88/base/index (CODE:302|SIZE:1656)
+ http://192.168.3.88/base/index.php (CODE:302|SIZE:1656)
=> DIRECTORY: http://192.168.3.88/base/languages/
=> DIRECTORY: http://192.168.3.88/base/scripts/
=> DIRECTORY: http://192.168.3.88/base/setup/
=> DIRECTORY: http://192.168.3.88/base/sql/
=> DIRECTORY: http://192.168.3.88/base/styles/

--- Entering directory: http://192.168.3.88/manual/ ---
+ http://192.168.3.88/manual/env (CODE:200|SIZE:14596)
+ http://192.168.3.88/manual/footer (CODE:200|SIZE:123)
+ http://192.168.3.88/manual/handler (CODE:200|SIZE:16511)
+ http://192.168.3.88/manual/header (CODE:200|SIZE:316)
=> DIRECTORY: http://192.168.3.88/manual/howto/
=> DIRECTORY: http://192.168.3.88/manual/images/
+ http://192.168.3.88/manual/index (CODE:200|SIZE:9364)
+ http://192.168.3.88/manual/index.html (CODE:200|SIZE:9364)
+ http://192.168.3.88/manual/install (CODE:200|SIZE:17808)
+ http://192.168.3.88/manual/LICENSE (CODE:200|SIZE:11358)
+ http://192.168.3.88/manual/location (CODE:200|SIZE:2869)
+ http://192.168.3.88/manual/logs (CODE:200|SIZE:27582)
=> DIRECTORY: http://192.168.3.88/manual/misc/
```

```
+ http://192.168.3.88/manual/install (CODE:200|SIZE:17808)
+ http://192.168.3.88/manual/LICENSE (CODE:200|SIZE:11358)
+ http://192.168.3.88/manual/location (CODE:200|SIZE:2869)
+ http://192.168.3.88/manual/logs (CODE:200|SIZE:27582)
=> DIRECTORY: http://192.168.3.88/manual/misc/
=> DIRECTORY: http://192.168.3.88/manual/mod/
=> DIRECTORY: http://192.168.3.88/manual/programs/
+ http://192.168.3.88/manual/sections (CODE:200|SIZE:6308)
+ http://192.168.3.88/manual/sitemap (CODE:200|SIZE:9917)
+ http://192.168.3.88/manual/windows (CODE:200|SIZE:27470)

--- Entering directory: http://192.168.3.88/phpmyadmin/ ---
+ http://192.168.3.88/phpmyadmin/calendar (CODE:200|SIZE:7893)
+ http://192.168.3.88/phpmyadmin/changelog (CODE:200|SIZE:25707)
+ http://192.168.3.88/phpmyadmin/ChangeLog (CODE:200|SIZE:10992)
=> DIRECTORY: http://192.168.3.88/phpmyadmin/config/
=> DIRECTORY: http://192.168.3.88/phpmyadmin/contrib/
=> DIRECTORY: http://192.168.3.88/phpmyadmin/css/
+ http://192.168.3.88/phpmyadmin/docs (CODE:200|SIZE:4583)
+ http://192.168.3.88/phpmyadmin/error (CODE:200|SIZE:1063)
+ http://192.168.3.88/phpmyadmin/export (CODE:200|SIZE:7893)
+ http://192.168.3.88/phpmyadmin/favicon.ico (CODE:200|SIZE:18902)
+ http://192.168.3.88/phpmyadmin/import (CODE:200|SIZE:7893)
+ http://192.168.3.88/phpmyadmin/index (CODE:200|SIZE:7893)
+ http://192.168.3.88/phpmyadmin/index.php (CODE:200|SIZE:7893)
=> DIRECTORY: http://192.168.3.88/phpmyadmin/js/
=> DIRECTORY: http://192.168.3.88/phpmyadmin/lang/
+ http://192.168.3.88/phpmyadmin/libraries (CODE:403|SIZE:287)
+ http://192.168.3.88/phpmyadmin/license (CODE:200|SIZE:18011)
+ http://192.168.3.88/phpmyadmin/LICENSE (CODE:200|SIZE:18011)
+ http://192.168.3.88/phpmyadmin/main (CODE:200|SIZE:7893)
+ http://192.168.3.88/phpmyadmin/navigation (CODE:200|SIZE:7893)
+ http://192.168.3.88/phpmyadmin/phpinfo (CODE:200|SIZE:0)
+ http://192.168.3.88/phpmyadmin/phpinfo.php (CODE:200|SIZE:0)
+ http://192.168.3.88/phpmyadmin/readme (CODE:200|SIZE:2630)
+ http://192.168.3.88/phpmyadmin/README (CODE:200|SIZE:2630)
=> DIRECTORY: http://192.168.3.88/phpmyadmin/scripts/
+ http://192.168.3.88/phpmyadmin/sql (CODE:200|SIZE:7893)
=> DIRECTORY: http://192.168.3.88/phpmyadmin/test/
=> DIRECTORY: http://192.168.3.88/phpmyadmin/themes/
+ http://192.168.3.88/phpmyadmin/TOD0 (CODE:200|SIZE:235)
```



```

--- Entering directory: http://192.168.3.88/base/admin/ ---
+ http://192.168.3.88/base/admin/index (CODE:200|SIZE:934)
+ http://192.168.3.88/base/admin/index.php (CODE:200|SIZE:934)

--- Entering directory: http://192.168.3.88/base/contrib/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/base/docs/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/base/help/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/base/images/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/base/includes/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/base/languages/ ---
+ http://192.168.3.88/base/languages/index (CODE:302|SIZE:0)
+ http://192.168.3.88/base/languages/index.php (CODE:302|SIZE:0)

--- Entering directory: http://192.168.3.88/base/scripts/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/base/setup/ ---
+ http://192.168.3.88/base/setup/index (CODE:200|SIZE:1748)
+ http://192.168.3.88/base/setup/index.php (CODE:200|SIZE:1748)

--- Entering directory: http://192.168.3.88/base/sql/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/base/styles/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/manual/howto/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/manual/images/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

```

```

--- Entering directory: http://192.168.3.88/manual/misc/ ---
+ http://192.168.3.88/manual/misc/FAQ (CODE:200|SIZE:155322)
+ http://192.168.3.88/manual/misc/footer (CODE:200|SIZE:204)
+ http://192.168.3.88/manual/misc/header (CODE:200|SIZE:319)
+ http://192.168.3.88/manual/misc/howto (CODE:200|SIZE:8867)
+ http://192.168.3.88/manual/misc/index (CODE:200|SIZE:4969)
+ http://192.168.3.88/manual/misc/index.html (CODE:200|SIZE:4969)
+ http://192.168.3.88/manual/misc/perf (CODE:200|SIZE:5682)
+ http://192.168.3.88/manual/misc/tutorials (CODE:200|SIZE:5793)

--- Entering directory: http://192.168.3.88/manual/mod/ ---
+ http://192.168.3.88/manual/mod/core (CODE:200|SIZE:173704)
+ http://192.168.3.88/manual/mod/footer (CODE:200|SIZE:204)
+ http://192.168.3.88/manual/mod/header (CODE:200|SIZE:319)
+ http://192.168.3.88/manual/mod/index (CODE:200|SIZE:7639)
+ http://192.168.3.88/manual/mod/index.html (CODE:200|SIZE:7639)

--- Entering directory: http://192.168.3.88/manual/programs/ ---
+ http://192.168.3.88/manual/programs/footer (CODE:200|SIZE:205)
+ http://192.168.3.88/manual/programs/header (CODE:200|SIZE:319)
+ http://192.168.3.88/manual/programs/httpasswd (CODE:200|SIZE:9143)
+ http://192.168.3.88/manual/programs/httpd (CODE:200|SIZE:6570)
+ http://192.168.3.88/manual/programs/index (CODE:200|SIZE:2467)
+ http://192.168.3.88/manual/programs/index.html (CODE:200|SIZE:2467)
+ http://192.168.3.88/manual/programs/other (CODE:200|SIZE:2173)

--- Entering directory: http://192.168.3.88/phpmyadmin/config/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/phpmyadmin/contrib/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/phpmyadmin/css/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

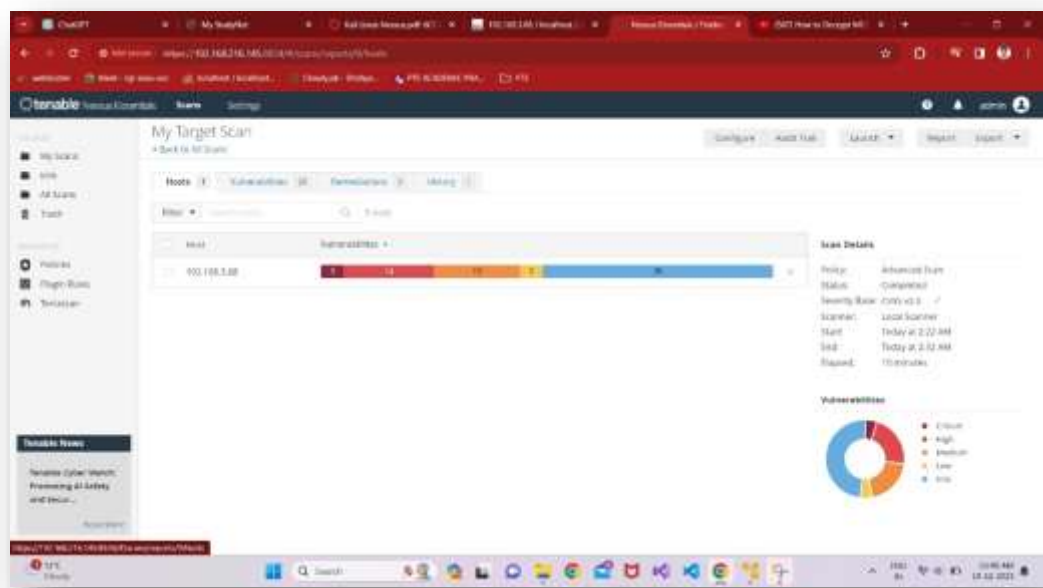
--- Entering directory: http://192.168.3.88/phpmyadmin/js/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.3.88/phpmyadmin/lang/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

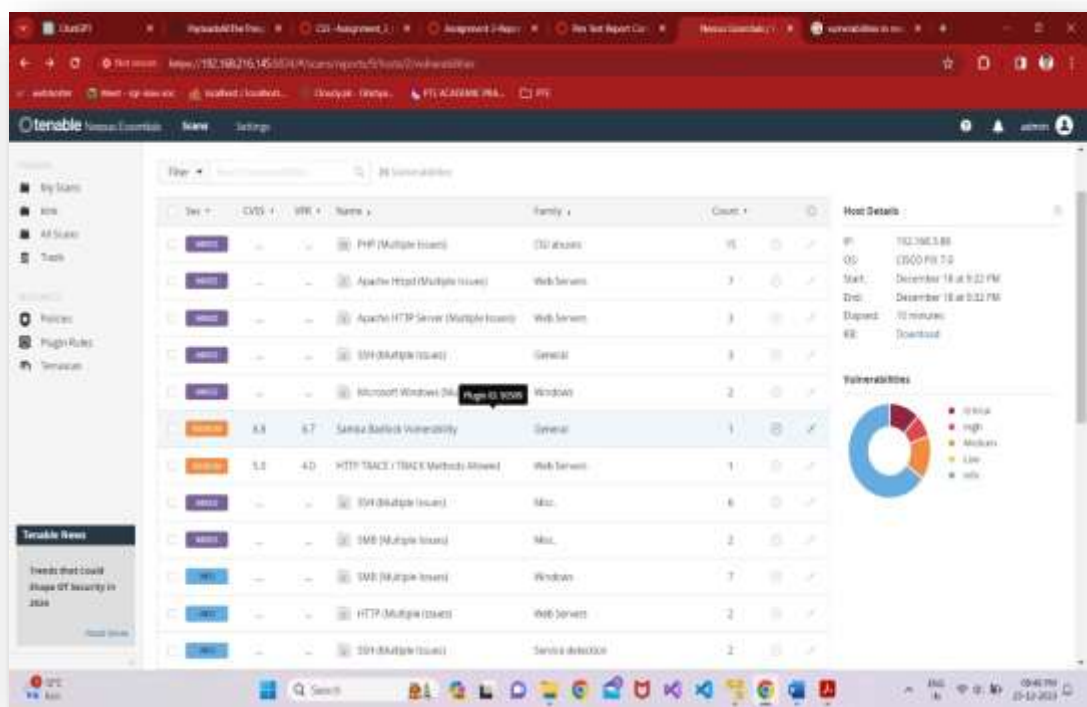
--- Entering directory: http://192.168.3.88/phpmyadmin/scripts/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

```

8.3 Nessus Scan



8.4 Nessus Scan vulnerabilities brief



Otenable Nessus Essentials | Scans | Settings

My Scans

- My Scans
- Myk
- All Scans
- Trash

My Scans

- Policies
- Plugins/Rules
- Terracott

Terracott News

Cybersecurity Snapshot: A Look Back at May 2023 Op...

Scan Results

Severity	CVSS	VPR	Name	Family	Count
Critical	10.0	10.0	PHP Unsupported Version Detection	CGI abuses	1
High	7.8	8.9	PHP < 5.3.12 / 5.4.2 CGI Query String Conf.	CGI abuses	1
High	7.5	7.3	PHP < 4.4.5 Multiple Vulnerabilities	CGI abuses	1
High	7.5	6.7	PHP < 4.4.0 Multiple Vulnerabilities	CGI abuses	1
High	7.5	6.7	PHP < 4.4.5 Multiple Vulnerabilities	CGI abuses	1
High	7.5	6.7	PHP < 5.2.11 Multiple Vulnerabilities	CGI abuses	1
High	7.5	6.3	PHP < 5.2.0 Multiple Vulnerabilities	CGI abuses	1
High	7.5	6.3	PHP < 5.3.9 Multiple Vulnerabilities	CGI abuses	1
High	6.8	6.7	PHP < 5.3.12 Multiple Vulnerabilities	CGI abuses	1
High	6.8	6.7	PHP < 5.3.11 Multiple Vulnerabilities	CGI abuses	1
High	6.4	5.3	PHP < 5.3.2 / 5.2.13 Multiple Vulnerabilities	CGI abuses	1
High	5.1	4.4	PHP < 5.2.15 Multiple Vulnerabilities	CGI abuses	1
High	5.0	5.0	PHP < 5.2.9 Multiple Vulnerabilities	CGI abuses	1

Scan Details

Policy: Advanced Scan
Status: Completed
Severity Base: CVSS v2.0
Scanner: Local Scanner
Start: December 19 at 2:22 AM
End: December 19 at 2:32 AM
Elapsed: 10 minutes

Vulnerabilities

Donut chart showing vulnerability distribution: Critical (red), High (orange), Medium (yellow), Low (green), Info (blue).

Otenable Nessus Essentials | Scans | Settings

My Target Scan / Apache Httpd (Multiple Issues)

My Scans

- My Scans
- Myk
- All Scans
- Trash

My Scans

- Policies
- Plugins/Rules
- Terracott

Terracott News

Cybersecurity Snapshot: A Look Back at May 2023 Op...

Scan Results

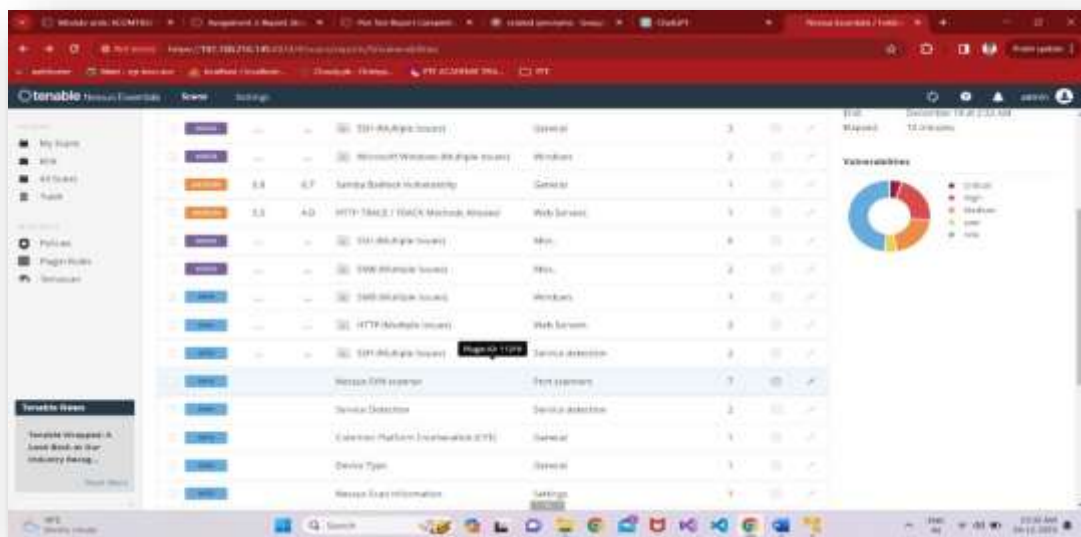
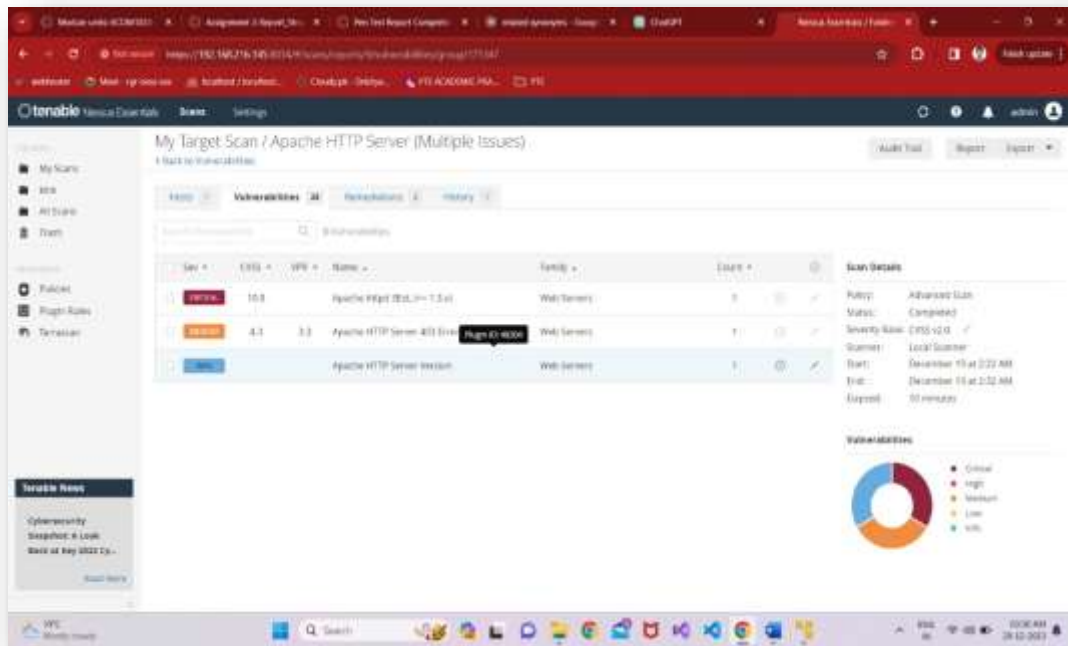
Severity	CVSS	VPR	Name	Family	Count
Critical	9.0	9.0	Apache 2.4.x + 2.4.56 Multiple Vulnerabilities	Web Servers	1
High	7.8	4.4	Apache 2.4.x + 2.4.58 Multiple Vulnerabilities	Web Servers	1
High	7.8	6.3	Apache 2.4.x + 2.4.55 Multiple Vulnerabilities	Web Servers	1
High	7.5	7.4	Apache 2.4.x + 2.4.53 Multiple Vulnerabilities	Web Servers	1
High	7.5	7.4	Apache 2.4.x + 2.4.54 Multiple Vulnerabilities	Web Servers	1
High	7.5	6.7	Apache 2.4.x + 2.4.49 Multiple Vulnerabilities	Web Servers	1
High	6.8	8.1	Apache 2.4.45 Multiple Vulnerabilities	Web Servers	1

Scan Details

Policy: Advanced Scan
Status: Completed
Severity Base: CVSS v2.0
Scanner: Local Scanner
Start: December 19 at 2:22 AM
End: December 19 at 2:32 AM
Elapsed: 10 minutes

Vulnerabilities

Donut chart showing vulnerability distribution: Critical (red), High (orange), Medium (yellow), Low (green), Info (blue).



8.5 Encrypted password file for WordPress

```
(kali@kali)~$ cat assgpass.txt
7b24afc8bc80e548d66c4e7ff72171c5

(kali@kali)~$
```

9. References

GeeksforGeeks (2019). *GeeksforGeeks | A computer science portal for geeks*. [online] GeeksforGeeks. Available at: <https://www.geeksforgeeks.org/>.

Kali (2018). *Our Most Advanced Penetration Testing Distribution, ever*. [online] Kali.org. Available at: <https://www.kali.org/>.

Wikipedia. (2020). *VMware*. [online] Available at: <https://en.wikipedia.org/wiki/VMware>.

Bork, K. (2021). *What is the Penetration Testing Execution Standard? » Triaxiom Security*. [online] Triaxiom Security. Available at: <https://www.triaxiomsecurity.com/what-is-the-penetrationtesting-execution-standard/>.

EDUCBA (2021). *What is XAMPP? | Complete Guide to What is XAMPP*. [online] EDUCBA. Available at: <https://www.educba.com/what-is-xampp/>.

HackTheBridge (2022). *Beginner's Guide to Netcat for Hackers*. [online] Medium. Available at: <https://medium.com/@HackTheBridge/beginners-guide-to-netcat-for-hackers-55abe449991d> [Accessed 27 Dec. 2023].

YouTube (2023). *YouTube*. *YouTube*. Available at: <https://www.youtube.com/>.

Tenable (2023). *Nessus Product Family*. [online] Tenable®. Available at: <https://www.tenable.com/products/nessus>.

freeCodeCamp (2014). *Learn to code | freeCodeCamp.org*. [online] Freecodecamp.org. Available at: <https://www.freecodecamp.org/>.

phpMyAdmin (2019). *phpMyAdmin*. [online] phpMyAdmin. Available at: <https://www.phpmyadmin.net/>.

hashes.com. (n.d.). *Hash Type Identifier - Identify unknown hashes*. [online] Available at: https://hashes.com/en/tools/hash_identifier.

GitHub (2023). *GitHub*. [online] GitHub. Available at: <https://github.com/>.

LinkedIn (n.d.). *LinkedIn*. [online] LinkedIn.com. Available at: <https://www.linkedin.com/>.

Study.com (2015). *Study.com | Take Online Courses. Earn College Credit. Research Schools, Degrees & Careers*. [online] Study.com. Available at: <https://study.com/>.